

ERP Security Architecture Case Study Report

April 17, 2026
Winter 2026

Jugadbeer Sangha
Brendan Lasko
Parth Patel

Introduction

The organization is a global software development company specializing in creating Enterprise Resource Planning (ERP) systems, which serve to integrate core business processes such as finance, human resources, supply chain, and sales into a centralized platform. This enables organizations to improve efficiency, reduce errors, and enhance decision-making through unified data access.

The company is currently headquartered in the United States with a branch office in Canada, and it serves over 200 enterprise customers across multiple regions, including Canada, the United States, the United Kingdom, Germany, Saudi Arabia, Singapore, and Japan.

Currently, the organization is transitioning from a partially on-premises environment to a cloud-based Software-as-a-Service (SaaS) ERP platform hosted in AWS. The company is also currently planning to adopt Artificial Intelligence (AI) within its workforce through implementing AI-driven features focused on enhancing productivity, automation, and security capabilities within its ERP system.

However, these new initiatives, including the cloud transition and AI adoption, have not undergone formal security or compliance assessments as of yet. As a result, the CEO has tasked the CISO team with evaluating the organization's internal security posture and product security before providing appropriate feedback and recommendations to ensure company operations, products, and services remain secure and compliant prior to customer usage.

The following report will detail the key findings of the CISO team regarding the current security posture of the organization. This will include an establishment of the security objectives that the team will focus on achieving, an in-depth analysis of the current security architecture diagram, and a breakdown of the key risks identified that the team hopes to resolve, as well as additional risks that will be out of scope. The report will conclude with detailing associated recommendations for the risks outlined, an improved security architecture diagram proposed for usage, and final notes regarding missing information that would occur throughout the project and the approximated implementation pipeline.

Security Objectives

1. Secure the Cloud ERP Platform

The first objective is to secure the new cloud ERP platform that the company is finalizing and ensure it follows regulatory compliance prior to deployment for customer usage. As the ERP system will handle highly sensitive business data across multiple organizations, any security vulnerability could result in severe financial, legal, and reputation harm. Ensuring that the platform is secure before release helps to reduce the likelihood of breaches and, as a result, prevents potential loss of business from customers.

2. Enable Secure AI Adoption

The second objective is to enable the safe and controlled adoption of AI across the organization's products and services. Given that the company has no prior experience with AI, and developers are already using AI tools without a structured governance plan, there is a significant risk of misuse, data leakage, and unreliable outputs. As a result, this objective focuses on ensuring AI is implemented with safe handling and usage practices, taking a proactive approach regarding security, as opposed to a reactive approach.

3. Protect Customer Data & Ensure Compliance

The third objective is to protect sensitive customer data and ensure compliance with regulatory requirements across all operating regions regarding data transmission, processing, and storage across all operating jurisdictions. With customers spanning multiple regions, the organization must ensure they comply with various regional data protection laws, including GDPR for the UK and PIPEDA for Canada, to name a few. Additionally, the organization currently lacks a data residency strategy and the utilization of compliance frameworks in place. Failure to comply with these data protection laws could lead to significant legal and regulatory consequences, as well as a loss of key contracts, particularly in regions with strict data sovereignty requirements, such as a key customer in Saudi Arabia with a \$5 million contract.

4. Secure Cloud Transition & Expansion

The fourth objective is to support the organization's transition to cloud infrastructure and expansion into new markets securely. As the transition and expansion processes can expose the organization to several new attack surfaces and introduce new threats such as misconfigurations, insecure APIs, and a lack of visibility, these processes and their associated risks should be accounted for. Through embedding security into the transition process, the organization can help ensure that risks are mitigated as the organization scales and builds into the expansion, once again focusing on a proactive approach to security rather than a reactive approach.

5. Maintain Service Availability & Trust

The final objective is to maintain reliable and trusted service delivery. Throughout the transition to the cloud environment and adoption of AI, the organizational operations must remain functional for customers. Any disruption to ERP services could significantly impact core business operations and customer interactions, thus resulting in potential contractual penalties and reputational damage. Ensuring system availability and integrity is therefore essential to maintaining long-term business relationships.

Current State

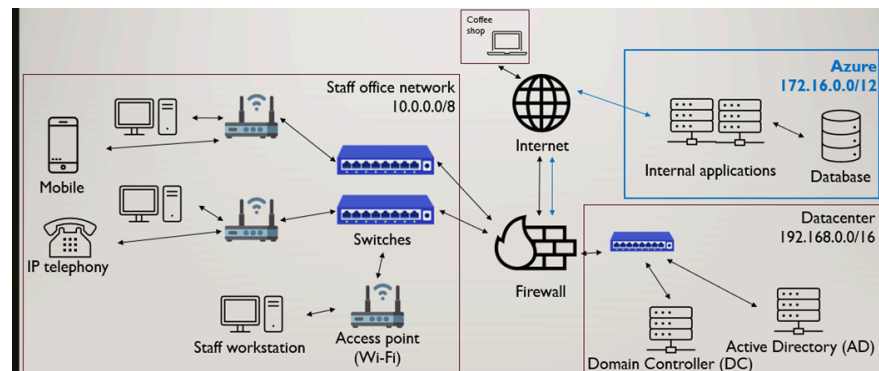


Figure 1: Original Security Architecture

The organization operates across three primary zones.

Zone 1: Staff Office Network

The Staff Office Network contains the internal corporate network and includes all employee devices such as laptops, workstations, and mobile devices. This environment is configured as a flat network, where all devices reside on the same subnet. While this simplifies network management, it significantly increases security risk. If a single device is compromised, an attacker can move laterally across the network without restriction, potentially gaining access to sensitive systems and credentials.

Zone 2: Datacenter

The on-premises data center hosts both the Active Directory and Domain Controller, which are responsible for authentication, user management, and policy enforcement. While this environment serves as the backbone of identity management, there is limited visibility into its security posture. There is no clear indication of hardening measures, logging, or monitoring capabilities, which raises concerns about its ability to detect and respond to threats.

Zone 3: Azure (Cloud)

The cloud environment is currently operating using Azure and houses various cloud-hosted internal applications and databases accessible from the internet. However, the architecture lacks clarity around secure configurations, such as encrypted connections, network segmentation, and access controls. Furthermore, there is no evidence of centralized monitoring or logging across cloud environments.

Remote access is facilitated through VPN connections, often from personal devices. This introduces additional risks, as unmanaged devices may not meet security standards and could

serve as entry points for attackers. Additionally, there is no clear implementation of multi-factor authentication (MFA) or single sign-on (SSO), further weakening identity security.

Overall, the current state reflects a lack of layered security controls, insufficient visibility, and outdated trust models. These weaknesses create a high-risk environment, particularly as the organization transitions to cloud and AI-driven systems.

Key Risk Breakdown

Domain 1: Network & Application Security

Unauthenticated communication between microservices

One of the most critical risks identified is the lack of authentication between microservices. In the current architecture, microservices implicitly trust each other with no verification whatsoever between them, meaning that once a service is compromised, an attacker can move freely across the entire system. Along with this, the system currently lacks any segmentation, authentication, or compensating control to limit the damage. Given that the ERP system processes sensitive customer information, we therefore felt this risk has both a high likelihood and a high impact and would overall be a critical risk.

Insecure API access controls are currently in place (API utilizes only the account number for authorization)

Another significant risk is the insecure design of the API used to connect to external services. The API relies solely on an account number for authentication, with no additional verification or authorization mechanisms. This allows attackers to easily impersonate users and perform unauthorized actions, such as initiating transactions, and the system is also currently lacking any session ID or other logging mechanism to help bind session activity to a real user identity. As such, we felt this risk would once again have a likelihood and high impact due to the ease of attack and the severe potential financial damage it could result in, thus characterizing the risk as an overall critical risk.

Domain 2: Identity & Access Management

Unmanaged cloud credentials (Developer accounts exist outside corporate identity)

In regard to the organization's identity and access management practices, we felt a major risk was the unmanaged cloud credentials that are currently used by the employees for development. Developer access to AWS is currently not integrated with the corporate identity system and lacks multi-factor authentication and an audit trail, limiting centralized visibility and risk oversight regarding cloud practices. For example, a developer named Bob was found to access AWS using a username not tied to their company email. As a result, compromised credentials may go undetected, and offboarding processes may fail to revoke access properly. Additionally, cloud

access is currently shared across regions without proper segregation, leading to an increase in the risk of unauthorized access. This risk is particularly concerning given the sensitivity of the data and systems involved, and thus, we felt this risk would have a medium likelihood with a high impact, making it an overall critical risk.

Domain 3: AI Security

Excessive privileges granted to AI agents with a lack of human oversight (Agents can perform sensitive actions autonomously)

Regarding the domain of AI security, we felt that the current plans of excessive privileges being granted to AI agents with a lack of human oversight regarding their functionality and access controls resulted in another major risk. As the CEO is actively pushing for rapid AI agent adoption, current plans include these agents being expected to perform sensitive actions, including creating user accounts and managing contracts. Without proper controls, including a lack of guardrails in place and human oversight, this could lead to attackers easily performing privilege escalation and other associated unauthorized activities with relative ease, resulting in incorrect decisions that could lead to financial loss and/or compliance violations. The lack of experience within the organization further heightens this risk, and as a result, we felt this risk would also have a medium likelihood and high impact, making it an overall high risk.

Domain 4: Data Governance & Compliance

Lack of data residency policies/strategy in place across operating jurisdictions

Regarding data governance & compliance, the organization was noted to have an absence of a data residency strategy, which presents a major concern, particularly given the organization's global customer base. As all data is assumed to currently be held in the US and Canada hosted cloud regions of AWS, this would violate the data protection laws put in place by additional regions that the organization operates in, resulting in non-compliance and thus hefty regulatory penalties and fines. Additionally, this could lead to a potential loss of business with key customers, such as the aforementioned key client in Saudi Arabia. As such, we felt this risk would have a high likelihood and medium impact, making it another overall high risk.

Unaudited AI tool dependencies for customers (No review of whether the company's AI tools conflict with regulatory restrictions)

Additionally, the use of external AI tools without appropriate auditing regarding regulatory compliance, we felt, would be another high risk. Recent regulatory actions, such as restrictions on certain AI platforms like Claude in the US, highlight the importance of ensuring that all third-party tools meet legal and security requirements. Failure to comply with such regulations could force key customers to terminate their contract with the organization, and the organization could also be found in violation of local laws, resulting in regulatory penalties or fines, as well as

a potential loss of business. As such, similar to the previous risk, we felt this risk would have a high likelihood and medium impact.

Domain 5: DevSecOps

Unvalidated codebase and lack of governance regarding AI development tools (No security assessment completed, and no controls around AI-assisted coding)

Our fifth domain of DevSecOps focuses on the risks of unvalidated codebases and a lack of governance regarding AI development tools. As mentioned earlier, the current adoption of AI and its associated features has not been part of any formal security assessments as of yet, and thus, vulnerabilities such as insecure code patterns, vulnerable open-source dependencies, and hardcoded secrets may already be present, which could lead to several potential threats from attackers. The use of AI tools without governance or review requirements further heightens this risk, as developers may unknowingly introduce flawed or insecure code. This highlights the need for a secure development lifecycle that incorporates automated security testing and clear governance policies to help ensure safe handling practices and an acceptable use policy of AI in the workforce. Additionally, this introduction of governance policies will also address the AI model creation for the organization that will be outsourced due to the organization's lack of developmental knowledge of AI.

Additional Risks (Out of Scope)

Domain 1: Network & Application Security → Lack of management regarding remote development from employees (Employees utilizing unmanaged VPNs to work)

In addition to the several domains of security risks associated with the migration of the Global ERP systems development company to a cloud-based SaaS platform with integrated AI-powered features and autonomous agents for business operations automation, there are other related risks. However, these risks are treated as a lower priority for the current phase of the transition plan due to multiple factors such as scope, impact, and feasibility constraints. First, the lack of management for employee use of unmanaged VPNs to drive remote development poses a risk, but compared to API-level and identity-based threats, which can have a catastrophic impact on critical systems and sensitive customer information, it is considered a low priority in favor of addressing the API and identity threat landscape.

Domain 3: AI Security → Ungoverned proposition to utilize customer data for proprietary AI model training

Secondly, there is the risk of an ungoverned proposition to utilize customer data for proprietary AI model training, which introduces compliance and privacy concerns. Examples include confidential enterprise information being exposed, violation of data protection regulations (across a customer base), and the chance of mismanaged AI model outputs that would result in

data leakage. Although these present significant concerns, the company should assign this as a lower priority in the current transition plan because the company is still in the planning phase, and there is no active implementation of AI deployment and established data pipelines handling customer data. This means there is no currently existing attack surface related to AI production systems at this time of the transition. Addressing the use of customer data to train AI models can be done through implementing structured governance frameworks, policies, and compliance strategies, but it should be put on hold until other vulnerabilities within the cloud ERP environment have been dealt with. This includes addressing the main security risks, such as unauthenticated communication between microservices, insecure API controls, unmanaged cloud credentials, and weak identity and access management practices. By prioritizing identity management and microservice authentication, it helps create a foundation for the remaining security controls in the environment, as there would be a properly defined structure of how users, applications, and services should be authenticated and the level of access they would get. Having a structured governance plan for identity and access management (IAM), it helps ensure there is a baseline to support all other security controls in other domains, such as network security, DevSecOps controls, and AI governance.

Domain 6: Security Operations → Lack of centralized logging and threat visibility (Lack of log aggregation), and the Security team being understaffed and heavily overworked

The third low-prioritized risk would be the lack of centralized logging and having limited staff. This is because these risks have more of an impact on detection and response, rather than prevention. The main priority should be to address high-risk vulnerabilities and security gaps, such as insecure API access design and weak identity management controls. For example, the cloud ERP solution has system microservices that blindly trust each other with a lack of authentication and authorization controls. In addition, the development team designed the user identification of the API based on an account number that is used to authorize transactions. As a result, this expands the attack surface and introduces a critical risk attack vector, where the attacker could easily compromise an account number and carry out actions without proper identity and access control. If these vulnerabilities are not addressed, they can have a detrimental impact on core business processes and confidential customer information, resulting in a higher priority compared to logging and issues related to limited staffing. Another reason to prioritize API and identity management over logging and staffing is that the implementation of centralized logging and addressing limited staff comes with high costs, time, and drastic organizational changes, such as deploying high-level SIEM solutions into the security environment and hiring talented staff in an emerging technology field. These solutions are considered to be long-term improvements that would not happen overnight. Hence, the prioritization of addressing the API and identity management security issues is more important to mitigate immediate threats to the company.

Recommendations

Domain 1: Recommendations for Network & Application Security

The risks of unauthenticated communication between microservices and insecure API access controls that use account numbers for authorization are very important to address because they can compromise the confidentiality, integrity, and availability of the ERP cloud environment. If there are no properly implemented authentication and authorization measures, attackers could take advantage of API's and internal service communication to retrieve sensitive customer information and move laterally across the network. As a result, there needs to be serious attention allocated to the lack of defined trust boundaries.

To mitigate these risks, cheap options would include implementing stronger API authentication and authorization measures using Amazon Cognito (a low-cost option). This tool would help drive the basis of identity verification with the help of secure token-based authentication, such as using JWT tokens to enforce restrictions in allowing only trusted users and applications to be granted access to backend services. In addition, this would support the objective of protecting sensitive customer business data while also ensuring global regulatory compliance is being met. Amazon Cognito also uses fine-grained access controls, so that users can authenticate themselves, receive a JWT token, and be granted the appropriate access rights. Another cheap option would be to use Amazon API Gateway (low-cost option) to establish a centralized control point to manage incoming API requests. Other features that Amazon API Gateway provides include throttling of traffic, authorization of API calls, rate limiting, request filtering, and input validation, all of which would help prevent the likelihood of attacks such as denial of service attacks and injection attacks. As a result, this would help maintain trusted and reliable service delivery, as this tool would help provide system availability and resiliency against an emerging threat landscape.

To address the lack of authentication between microservices, one option (high-cost option) would be to implement a zero-trust architecture, as it enforces the principle of “never trust, always verify”. The assumption that internal traffic is always secure can create dangerous attack surfaces and lead to consequences in a cloud environment. However, the implementation of a service mesh through tools such as AWS App Mesh or Istio, while also integrating mutual TLS (mTLS), can help encrypt and authenticate all communication between microservices. As a result, this would strengthen network security and provide authentication controls to help the company prevent the event of a microservice being compromised. Moreover, these controls are considered flexible security mechanisms that can be implemented across multiple regions and services, which is important for multi-region deployments that differ in regulations and attack surfaces. Overall, these controls support both the objectives of securing the ERP cloud platform prior to customer use and ensuring trusted and reliable service delivery.

Domain 2: Recommendations for Identity and Access Management (IAM)

Addressing the risk of unmanaged cloud credentials where developer accounts exist outside of corporate identity should be prioritized in the transition to a SaaS based cloud platform. This is because if this risk is left untreated, then blind spots may remain in access controls. In addition, developer accounts may not be centrally managed, causing difficulties in imposing security policies, detecting unauthorized access, or denying authorization. As a result, this leads to an increased chance of the misuse of credentials and violation of regulatory requirements.

One solution to mitigate this risk is to implement Single-Sign On (SSO) and assign all accounts to AWS IAM Identity Center (low-cost option) to provide centralized identity management and policy enforcement. This would help the company enforce uniform authentication while moving towards the adoption of a secure cloud platform and satisfying compliance requirements. Another solution would be to implement AWS Multi-Factor Authentication (low-cost option) alongside AWS IAM, so that in the event of credentials being compromised, there is an extra layer of security to prevent unauthorized access and protect sensitive customer information. In addition, another option (high cost option) would be to implement Privileged Identity Management with the help of AWS IAM to help make sure that privileged access is granted when needed and under time constraints. This prevents developers from abusing privileged permissions and thereby enforcing the principle of least privilege. The last option to address this risk is to implement managed identities (roles) in AWS IAM (high cost option) to get rid of hardcoded credentials and instead allow for services to authenticate using managed and rotated identities (through AWS generating temporary access keys that are accessible for a certain time period) to lower the risk of credential leaks and unauthorized access. This also helps remove the burden of storing long-term access keys, which are vulnerable to being compromised. By establishing strong methods to control how services authenticate and how identities are managed, the company will be able to fill in the security gaps for identity and access management that drives the full security foundation.

Domain 3: Recommended options for AI Security

The risks associated with AI security are critical due to the level of access being granted to AI agents within the ERP system. They are expected to perform sensitive operations such as account creation, contract renewals, and workflow automation. If left unchecked, excessive privileges and a lack of human oversight could lead to unauthorized actions being taken by AI, which leads to system misuse. Additionally, AI systems are vulnerable to issues, such as incorrect outputs. In a business-critical environment like ERP, this could result in incorrect financial decisions, improper access provisioning, or compliance violations. Given that the organization lacks prior experience with AI, the risk of misconfiguration or misuse increases, making it a high-impact risk if not properly addressed.

To mitigate these risks at a cheap level, the organization should implement strict access controls and governance mechanisms for all AI systems. Pushing the principle of least privilege ensures

that AI agents only have access to the minimum resources required to perform their task. This helps reduce the potential impact of misuse or compromise. Another option is to have human approval for sensitive actions. Having a human approve sensitive actions like modifying user accounts or executing financial operations will mitigate these risks. For more advanced and expensive security, the organization should implement a Human-in-the-Loop (HITL) model. Human oversight being connected to AI workflows helps ensure that key decisions are reviewed and validated before execution. Also, automated auditing and monitoring of AI activities is another way. Logging all AI actions allows the organization to detect anomalies, investigate incidents, and maintain accountability over time. To support these controls, the organization can implement frameworks such as the NIST AI Risk Management Framework, which guides on identifying, assessing, and managing AI-related risks. From a tooling perspective, services such as AWS Bedrock can be used to build and deploy AI applications within a controlled and secure environment. AWS Bedrock helps provide built-in capabilities for managing model access, enforcing guardrails, and integrating with existing cloud security controls. Overall, securing AI within the ERP platform requires a balance between innovation and control. By enforcing access controls strictly, embedding human oversight, and implementing monitoring, the organization can safely leverage AI capabilities while minimizing risks.

Additionally, regarding the creation of the AI model itself, the organization should seek to outsource the work to a third-party vendor. As the organization has no experience with AI, outsourcing the model creation, as opposed to in-house development, can help ensure not just an efficient use of resources, time, and developmental costs, but also can prevent potential accidental vulnerabilities such as misconfigurations, which could be easily exploited by attackers. To support these efforts, the organization should ensure implementation of a strong Cyber Supply Chain Risk Management (C-SCRM) approach to maintain executive oversight regarding third-party vendors. The organization should also enforce vendor security controls, such as contractual clauses regarding security expectations of the model's development and regarding collecting, utilizing, and handling training data that would be used to train the model. Regular auditing should also be implemented to ensure the organization continuously monitors associated risk.

Domain 4: Recommendations for Data Governance & Compliance

Data governance and compliance pose a critical risk due to the organization's global operations and lack of a defined data residency strategy. With customers across multiple jurisdictions, including regions with strict data protection laws such as the European Union and Saudi Arabia, failure to control where data is stored and processed can result in regulatory violations, financial penalties, and loss of key business contacts. Additionally, the use of unaudited AI tools introduces further risk, as certain tools may be restricted or banned in specific regions. If these tools are integrated into the organization's services without proper validation, it could lead to

legal consequences and reputation damage. Overall, the lack of governance over data and AI tool usage creates a high-risk environment with both legal and financial implications.

To address these risks at a cheap level, the organization should establish data classification & residency policies. Data should be categorized based on sensitivity, and clear rules should be defined on where each category can be stored and processed. Manual audits should also be conducted to verify data locations and assess the compliance of AI tools currently in use. At the more expensive level, the organization should implement automated data residency enforcement mechanisms. This involves configuring cloud environments to ensure that data is stored and processed only within approved geographic regions. Centralized governance controls should also be established to manage data consistently across multiple regions and cloud environments. Also, a policy enforcement layer should be introduced to restrict the use of certain AI services based on geographic or regulatory requirements. For example, specific AI tools could be blocked for customers in regions where those tools are restricted. To support these initiatives, tools such as AWS Control Tower can be used to enforce governance policies across multiple AWS accounts and regions. This enables the organization to standardize configurations and maintain compliance at scale. In addition, Amazon Macie can be used to automatically discover, classify, and monitor sensitive data within the organization's cloud environment. From a governance point of view, adopting the ISO 27001 standard will help provide a structured framework for managing information security risks and ensuring compliance with global best practices. Overall, effective data governance requires a combination of policy, technology, and process. By implementing structured controls and leveraging automation, the organization can ensure compliance across all operating regions while maintaining customer trust.

Domain 5: Recommendations for DevSecOps

It is important to address the risk of having an unvalidated codebase and a lack of governance regarding AI development tools, such as having no security assessments completed and no controls around AI-assisted coding. The reason is that leaving this risk untreated can lead to hidden vulnerabilities, such as insecure logic or misconfigurations from AI-generated code that could be exploited in applications. If proper validation checks on AI-generated code or open source code are not done and they are left bypassing security checks, there can be an increased chance of customer data being exploited. In addition, the lack of governance structure around AI development tools can leave sensitive data exposed to AI tools, resulting in data leakage and compliance risks. Furthermore, the lack of security assessments being conducted on AI-assisted coding can escalate to an accumulation of cybersecurity debt, as the number of unresolved vulnerabilities would continue to increase. Hence, it's important to address these concerns through the implementation of security controls.

One strategy would be to surround the security controls with a defense-in-depth approach to protect both the development pipeline and runtime environment with safe AI use in the picture.

One example of a security control that should be implemented would be using automated static code analysis through Amazon CodeGuru Reviewer (a low-cost tool) within the AWS CodePipeline (low-cost tool). This is to help ensure code is always scanned for vulnerabilities before it is deployed into production. In addition, this helps to address security flaws early in the development lifecycle. This would help in securing the ERP cloud platform before customer use. Another strategy would be to create structured AI governance policies and conduct mandatory code reviews using AWS CodeCommit to ensure all AI-generated code is checked by developers and to lower the chance of unsafe code entering production. This helps to maintain safe and controlled adoption of AI across company products and services, while also ensuring regulatory compliance.

In terms of runtime protection, another AWS service, such as AWS Web Application Firewall (high cost option), can be used to monitor and filter malicious traffic to prevent injection attacks, while also using another tool, such as Dynatrace (high cost option), to monitor for vulnerable aspects in real time. These controls are significant because they help protect production applications in case vulnerabilities have been missed during development. As a result, this helps support the security objective of reliable service delivery. Together, these controls should be integrated into a defense-in-depth strategy to get enhanced layers of security surrounding the use of AI in the development lifecycle.

Security Architecture Overview

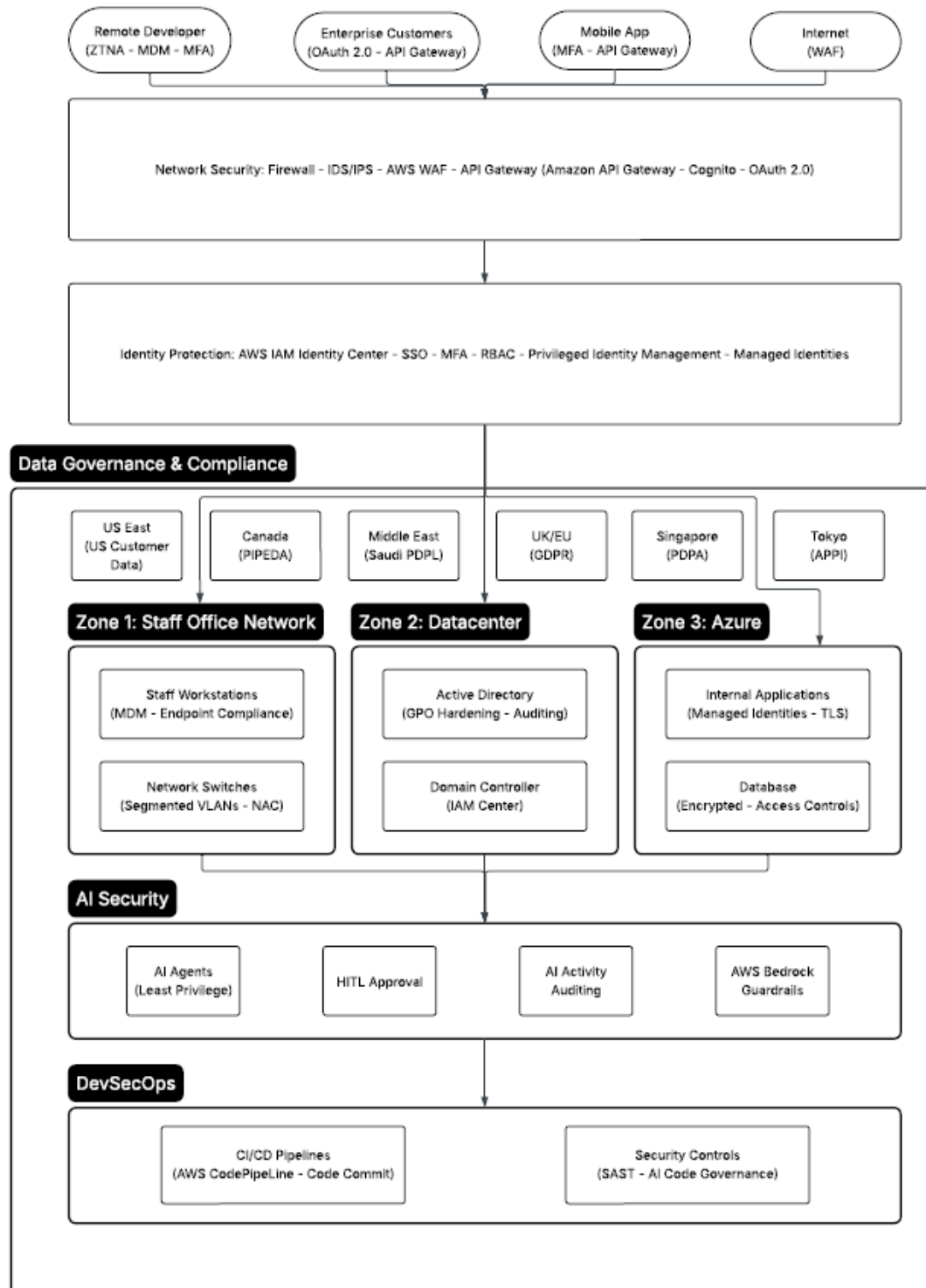


Figure 2: New and improved security architecture for ERP Cloud Platform

After reviewing the original architecture and analyzing its security gaps and flaws, the team came together to create a new and improved security architecture diagram that prioritized using a

defense-in-depth approach. As seen in Figure 2, the diagram has been divided into multiple layers.

At the top and outermost layer is the external access barrier, which houses all the entry points, including remote developers, enterprise customers, mobile app users, and internet access, all being secured with our recommended mitigations. For example, the remote developers would use any combination of Zero-Trust Network Access (ZTNA), Mobile Device Management (MDM), and Multi-Factor Authentication (MFA) to ensure that the developers are verified and only compliant devices can connect and access the network. In contrast, for our enterprise customers, we would use OAuth 2.0 (an industry-standard protocol for authorization) and Amazon Cognito to ensure secure authentication and prevent insecure API access. For mobile users, we would implement MFA and an API Gateway that would prevent unauthorized access and manage all API traffic. In terms of the Internet, we would use a Web Application Firewall (WAF) to ensure there is continuous monitoring, filtering, and blocking of malicious traffic such as abusive API requests, automated threats, and other attacks.

The second layer of the new security architecture diagram is for network security, in which we would add an Intrusion Detection/Prevention System (IDS/IPS) to the existing firewall and other tools operating in the external layer. This would help with ensuring proactive detection and response, as well as prevention against emerging attacks. There would also be an Amazon service, known as Amazon API Gateway, implemented in this layer to serve as a centralized entry point for all APIs, but also to enforce authentication and rate limiting to protect against potential denial of service attacks.

The third layer is focused on enforcing and managing the aforementioned identity and access management control measures introduced for each user, including AWS Identity and Access Management (AWS IAM), Single-Sign On (SSO), and Role-based Access Controls (RBAC), to name a few. Additionally, security controls such as Privileged Identity Management (PIM) and Managed Identities would be implemented to offer temporary admin privileges and to remove vulnerable hardcoded credentials in applications, respectively, further strengthening authentication, authorization, and accounting in the system.

The remaining layers below are subject to local data governance and protection laws based on each operating region, such as the Personal Information Protection and Electronic Documents Act (PIPEDA) for Canada and the Personal Data Protection Law (PDPL) for Saudi Arabia. To achieve this, all subsequent layers of the security architecture would be region-dependent, allowing for easy enforcement and ensuring data is stored, transmitted, and processed within each country's respective cloud region.

Similar to the original security architecture, the network would be divided into three distinct zones (Staff Office Network, Data Center, and Azure) that would preserve the original features, but would include enhanced security such as VLAN segmentation and Network Access Controls

(NAC) for the office staff network to prevent lateral movement. Other security measures would include Group Policy Object (GPO) hardening, auditing for the Active Directory located in the data center, and implementing Transport Layer Security (TLS) for the cloud applications in Azure.

Below are the zones, including the AI Security layer and DevSecOps layer. Inside the AI Security layer, security policies such as least privilege for all AI agents would be implemented to help limit the scope of the agents' actions. Additionally, security measures such as Human In The Loop (HITL) would be enforced to approve sensitive actions, as well as AI auditing and AWS Bedrock guardrails to prevent unsafe AI outputs.

Lastly, the DevSecOps layer would focus on security controls to ensure secure development, including CI/CD pipelines through AWS CodePipeline and AWS CodeCommit services, as well as security controls for static code analysis through Static Application Security Testing (SAST) to help identify vulnerabilities throughout development, and AI code governance.

Missing Information

While the analysis identifies several critical risks and proposed solutions, there are key pieces of information that are missing that impact the design and implementation of the security architecture. One of the major gaps is the absence of a clearly defined security budget. While an inference can be made of possessing a relatively large budget due to the large size of the organization and wealthy customer contracts, without a complete understanding of financial constraints, it is difficult to determine the feasibility of implementing advanced security tools and solutions. This uncertainty thus necessitated the inclusion of both low-cost and high-cost recommendations throughout the architecture to ensure options are available until a finalized valuation is presented.

Another important gap is the lack of visibility into existing identity and access management controls. It is unclear whether the organization has already implemented solutions such as multi-factor authentication, single sign-on, or privileged access management. This information is crucial in determining whether the organization should enhance existing systems or deploy new ones.

There is also limited information regarding customer contracts and data processing agreements. These agreements often define legal obligations related to data handling, storage, and processing. Without reviewing these contracts, there is a risk that proposed solutions may not fully align with customer requirements or regulatory obligations. Addressing these gaps would enable a more precise and accurate security architecture, ensuring that recommendations are both practical and aligned with the business constraints.

Implementation Pipeline

To effectively implement the proposed security architecture, a phased approach is recommended. This allows the organization to prioritize critical risks while gradually introducing more advanced security controls.

Phase 1 (0-3 Months): Immediate Risk Reduction

The initial phase focuses on addressing the most critical and easily exploitable vulnerabilities. Key initiatives include implementing multi-factor authentication (MFA) across all systems, enforcing single sign-on (SSO) for centralized identity management, and securing APIs through proper authentication mechanisms such as OAuth 2.0.

These controls provide immediate improvements in access security and significantly reduce the likelihood of unauthorized access. Given their relatively low complexity and high impact, they should be prioritized.

Phase 2 (3-6 Months): Structured Security Controls

The second phase introduces more structured and scalable security measures. This includes deploying API gateways to centralize and secure API traffic, implementing logging and monitoring solutions for both cloud and AI systems, and establishing data classification frameworks.

During this phase, the organization should also begin implementing governance controls for AI systems, including activity logging and oversight mechanisms. These measures enhance visibility and enable proactive threat detection.

Phase 3 (6-12 Months): Advance Security Architecture

The final phase focuses on implementing advanced security capabilities that align with modern best practices. This includes adopting a zero-trust architecture, where all access is continuously verified, and implementing service mesh technologies to secure communication between microservices using mutual TLS.

Additionally, full AI governance frameworks should be established, incorporating human-in-the-loop systems, automated auditing, and strict policy enforcement. These controls ensure that AI systems operate securely and responsibly at scale.

References:

Amazon Web Services. (n.d.). *Using tokens with identity providers in Amazon Cognito user pools*. Retrieved April 17, 2026, from <https://docs.aws.amazon.com/cognito/latest/developerguide/amazon-cognito-user-pools-using-tokens-with-identity-providers.html>

Amazon Web Services. (n.d.). *Building fine-grained authorization using Amazon Cognito, API Gateway, and IAM*. Retrieved April 17, 2026, from <https://aws.amazon.com/blogs/security/building-fine-grained-authorization-using-amazon-cognito-api-gateway-and-iam/>

Amazon Web Services. (n.d.). *Amazon API Gateway*. Retrieved April 17, 2026, from <https://aws.amazon.com/api-gateway/>

Amazon Web Services. (n.d.). *AWS App Mesh*. Retrieved April 17, 2026, from <https://aws.amazon.com/app-mesh/>

Istio. (n.d.). *What is Istio?* Retrieved April 17, 2026, from <https://istio.io/latest/docs/overview/what-is-istio/>

MSP360. (n.d.). *IAM identities explained*. Retrieved April 17, 2026, from <https://www.msp360.com/resources/blog/iam-identities/>

Amazon Web Services. (n.d.). *AWS Identity and Access Management (IAM)*. Retrieved April 17, 2026, from <https://aws.amazon.com/iam/>

Amazon Web Services. (n.d.). *AWS IAM Identity Center*. Retrieved April 17, 2026, from <https://aws.amazon.com/iam/identity-center/>

Omada. (n.d.). *Privileged identity management (PIM)*. Retrieved April 17, 2026, from <https://omadaidentity.com/glossary/privileged-identity-management/>

Amazon Web Services. (n.d.). *Amazon CodeGuru Reviewer*. Retrieved April 17, 2026, from <https://aws.amazon.com/codeguru/reviewer/>

Amazon Web Services. (n.d.). *AWS CodeCommit user guide*. Retrieved April 17, 2026, from <https://docs.aws.amazon.com/codecommit/latest/userguide/welcome.html>

Amazon Web Services. (n.d.). *AWS WAF*. Retrieved April 17, 2026, from <https://aws.amazon.com/waf/>

Dynatrace. (n.d.). *Application performance monitoring*. Retrieved April 17, 2026, from <https://www.dynatrace.com/solutions/application-monitoring/>

Amazon Web Services. (n.d.). *AWS CodePipeline features*. Retrieved April 17, 2026, from <https://aws.amazon.com/codepipeline/features/>

Palo Alto Networks. (n.d.). *NIST AI risk management framework (AI RMF)*. Retrieved April 17, 2026, from <https://www.paloaltonetworks.com/cyberpedia/nist-ai-risk-management-framework>

Amazon Web Services. (n.d.). *Amazon Bedrock*. Retrieved April 17, 2026, from <https://aws.amazon.com/bedrock/>

Amazon Web Services. (n.d.). *AWS Control Tower*. Retrieved April 17, 2026, from <https://aws.amazon.com/controltower/>

Amazon Web Services. (n.d.). *Amazon Macie*. Retrieved April 17, 2026, from <https://aws.amazon.com/macie/>

Advisera. (n.d.). *What is ISO 27001?* Retrieved April 17, 2026, from <https://advisera.com/27001academy/what-is-iso-27001/>